

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

Resource 05

AI Governance Roadmap

A Five-Phase Path from Ad Hoc AI Use to a Managed Program

NIST AI RMF 1.0 | ISO/IEC 42001:2023

Resource ID	TSEC-AI-05
Category	AI Governance
Framework Alignment	NIST AI RMF 1.0; ISO/IEC 42001:2023; AI governance maturity model
Version	1.1
Published	July 2026
Intended Audience	CISOs, CTOs, Compliance Officers, Boards & Executive Sponsors
Prepared By	TSEC Risk & Cyber Advisory LLC
Classification	Public — For Educational & Advisory Use

TSEC Compliance Resource Library — www.tsecgrc.com/resources

Table of Contents

Table of Contents.....	2
Executive Summary	4
AI Governance Maturity Overview.....	4
Roadmap Timeline	5
Phase 1 — Discover	6
Objective	6
Core Activities	6
Roles Involved.....	6
Common Blockers	6
Phase Deliverable	6
Phase 2 — Assess.....	6
Objective	6
Core Activities	7
Roles Involved.....	7
Common Blockers	7
Phase Deliverable	7
Phase 3 — Govern	8
Objective	8
Core Activities	8
Roles Involved.....	8
Common Blockers	8
Phase Deliverable	8
Phase 4 — Implement.....	8
Objective	8
Core Activities	9
Roles Involved.....	9
Common Blockers	9
Phase Deliverable	9
Phase 5 — Monitor	10
Objective	10
Core Activities	10
Roles Involved.....	10
Common Blockers	10
Budget & Resourcing Considerations.....	10
Board Reporting Template	11

KPIs	11
Common Pitfalls.....	12
Next Steps	12
Glossary of Key Terms.....	12
About TSEC & Next Steps	13

Executive Summary

Most organizations do not lack the will to govern AI responsibly — they lack a sequence. AI governance touches policy, security, data, procurement, legal, and executive oversight simultaneously, and without a phased plan it is easy to either stall on comprehensive planning or bolt on disconnected controls that do not add up to a defensible program.

This roadmap lays out five practical phases — Discover, Assess, Govern, Implement, and Monitor — that take an organization from an unmanaged, ad hoc state to a documented, auditable AI governance program aligned with the NIST AI Risk Management Framework and ISO/IEC 42001. Each phase includes its objective, core activities, typical timeline, involved roles, common blockers, and the artifacts that should exist by the end of it. Organizations already running an ISO 27001 or SOC 2 program will recognize the underlying rhythm — this roadmap extends that same operating model into AI, rather than asking the organization to build a second one from scratch.

AI Governance Maturity Overview

Before starting, it is worth locating the organization honestly on a maturity curve. Industry maturity models for AI governance generally describe five levels: Initial (ad hoc, undocumented), Repeatable (practices exist but vary by team), Defined (standardized and documented company-wide), Managed (implemented and monitored for effectiveness), and Optimizing (continuously improved against changing regulatory and business requirements).

Maturity Level	What It Looks Like
1 — Initial	AI tools adopted informally; no inventory, no policy, no accountable owner.
2 — Repeatable	Individual teams have their own informal practices; no organization-wide standard.
3 — Defined	Documented policy and process exist company-wide but are not fully adopted everywhere.
4 — Managed	Governance is documented, implemented, and actively monitored for effectiveness.
5 — Optimizing	Governance is continuously refined against new regulatory and business requirements.

The five-phase roadmap that follows is designed to move an organization from Level 1 or 2 to a solid Level 4 — a managed, evidenced program — over a realistic multi-quarter timeline. Level 5 is an ongoing discipline, not a one-time project, and is addressed in the Monitor phase and the KPIs section.

Roadmap Timeline

A realistic timeline for a mid-sized organization running all five phases for the first time. Organizations with more mature existing risk programs (e.g., established ISO 27001 or SOC 2 practices) can typically compress Govern and Implement.

Phase	Typical Duration	Can Run in Parallel With
1 — Discover	3–4 weeks	N/A (foundational)
2 — Assess	4–6 weeks	Late Discover, for systems already identified
3 — Govern	4–8 weeks	Assess (policy drafting can begin before assessment completes)
4 — Implement	2–4 months, prioritized by risk tier	Govern (early controls can roll out as policy is finalized)
5 — Monitor	Ongoing from end of Implement forward	All phases (monitoring of already-approved systems starts immediately)

Phase 1 — Discover

Objective

Establish visibility into what AI is actually in use before writing any policy. Most organizations underestimate this significantly — AI is often already running inside SaaS tools the organization did not select for their AI features specifically.

Core Activities

- ☐ Inventory internally built AI/ML systems, including shadow projects run by individual data science or engineering teams.
- ☐ Inventory embedded AI features in existing SaaS vendors (CRM, HR, support, productivity tools) — review vendor release notes and admin consoles, not just contracts.
- ☐ Survey or technically detect employee use of public generative AI tools (browser extension telemetry, network visibility, or a short anonymous internal survey).
- ☐ Interview business unit leaders to surface planned or pilot AI initiatives that have not yet reached IT or security review.

Roles Involved

AI Governance Lead (drives the inventory effort); IT/Security (provides technical visibility tooling); Business Unit Leads (disclose team-level tool usage); Procurement (cross-references vendor contracts for AI features).

Common Blockers

- Employees under-report AI tool usage out of concern for repercussions — an amnesty period for voluntary disclosure improves accuracy.
- No single system of record exists for "all software in use," making SaaS-embedded AI features hard to find without a dedicated review.

Phase Deliverable

A baseline AI system inventory: what exists, who owns it, what data it touches, and a rough sense of scale (number of systems, number of vendors, estimated employee usage).

Phase 2 — Assess

Objective

Convert the inventory into a risk-ranked list using a consistent methodology, following the Map and Measure functions of the NIST AI RMF.

Core Activities

- ☐ Apply a standard risk assessment (see TSEC's AI Risk Assessment Checklist) to each inventoried system, covering governance, security, privacy, compliance, and third-party risk.
- ☐ Classify each system into a risk tier (Critical/High/Moderate/Low) based on the sensitivity of data involved and whether the system affects consequential decisions about individuals.
- ☐ Identify systems that may fall under specific regulatory obligations (EU AI Act high-risk categories, state automated-decision-making laws, sector-specific guidance).
- ☐ Prioritize remediation based on risk tier rather than attempting to address every system simultaneously.

Roles Involved

AI Governance Lead and Risk Assessor (run assessments); Legal/Compliance (confirms regulatory triggers); Security Engineering (validates technical risk claims).

Common Blockers

- Assessing every system with equal depth stalls the phase — tier systems quickly first, then go deep only on Critical/High.
- Business owners may not know enough about a vendor's AI feature to answer assessment questions, requiring a parallel vendor outreach.

Phase Deliverable

A risk register with every inventoried AI system rated, prioritized, and assigned an accountable owner.

Phase 3 — Govern

Objective

Put the organizational structure in place before scaling technical controls — governance without accountability tends to produce policies nobody follows.

Core Activities

- ☐ Designate an accountable owner for AI governance (an individual for smaller organizations, a cross-functional committee for larger ones spanning security, legal, data, and business leadership).
- ☐ Publish a written AI governance policy defining scope, roles, intake process, and acceptable use, referencing the risk tiers established in Phase 2.
- ☐ Define an intake and approval workflow for new AI use cases so that Phase 1's "discover after the fact" problem does not recur.
- ☐ Align the policy structure with ISO/IEC 42001 clauses where the organization intends to pursue certification, or with the NIST AI RMF Govern function where certification is not a near-term goal.

Roles Involved

Executive Sponsor (approves policy); AI Governance Lead (drafts and maintains it); Legal (reviews for enforceability and regulatory alignment).

Common Blockers

- Policies drafted in isolation by security or legal without business-unit input tend to be ignored — involve business stakeholders in the intake process design.
- Executive sponsorship secured verbally but never formalized leaves the policy without real authority when it is tested.

Phase Deliverable

An approved, published AI governance policy with clear ownership and an intake process for new AI use cases.

Phase 4 — Implement

Objective

Close the highest-priority gaps identified in Phase 2, starting with Critical and High risk-tier systems.

Core Activities

- ☐ Implement technical controls proportional to risk tier: access controls, data protection, human-in-the-loop review for consequential decisions, and monitoring for Critical/High systems first.
- ☐ Complete vendor due diligence (see TSEC's AI Vendor Due Diligence Checklist) for any third-party AI feature rated Critical or High.
- ☐ Update contracts and procurement templates to require AI-specific disclosures and terms going forward.
- ☐ Deliver targeted training to employees and teams operating higher-risk AI systems, and organization-wide awareness training on acceptable use.
- ☐ Document residual risk and obtain sign-off from the accountable owner for any risk the organization chooses to accept rather than fully remediate.

Roles Involved

IT/Security (implements technical controls); Procurement/Legal (updates contracts); AI Governance Lead (tracks remediation to closure); Business Unit Leads (deliver team-level training).

Common Blockers

- Remediation stalls when no one owns tracking it to closure — assign a single tracker, not a shared spreadsheet everyone assumes someone else is updating.
- Vendor due diligence findings arrive slowly if requests are vague; use the structured questionnaire in TSEC's AI Vendor Due Diligence Checklist to speed vendor responses.

Phase Deliverable

Evidenced remediation of Critical and High risk-tier findings, with residual risk formally documented and accepted where applicable.

Phase 5 — Monitor

Objective

Sustain the program. This is the phase most roadmaps skip, and the one that separates a Level 4 (Managed) program from a Level 2 program that quietly decays back into ad hoc practice.

Core Activities

- ☐ Re-run the AI system inventory on a recurring cadence (recommended: quarterly) to catch new tools before they become Phase 1 all over again.
- ☐ Monitor production AI systems for drift, degraded performance, and incidents, with a defined escalation path.
- ☐ Have internal audit or an equivalent independent function periodically test whether documented controls are actually operating.
- ☐ Track governance KPIs (below) and report them to executive leadership or the board on a recurring cadence.
- ☐ Revisit the governance policy and risk tiering when the regulatory landscape changes — AI regulation is moving quickly enough that an annual policy review is the minimum acceptable cycle.

Roles Involved

AI Governance Lead (owns the recurring cadence); Internal Audit (independent testing); Executive Sponsor/Board (receives KPI reporting).

Common Blockers

- Monitoring is treated as a project with an end date rather than a permanent operating function, and quietly stops after the first quarter.
- KPIs are tracked but never reviewed by anyone with authority to act on them, making the metric a formality rather than a lever.

Budget & Resourcing Considerations

AI governance does not require a large dedicated team to start, but it does require named time, not just named responsibility. Organizations without budget for a full-time AI governance role can still succeed by carving out a defined percentage of an existing role's time (commonly 20–40% of a compliance or security manager's capacity during Phases 1–4, tapering to a smaller ongoing allocation during Monitor).

Resourcing Model	Best Fit	Trade-off
Dedicated AI Governance Lead (full-time)	Organizations with 10+ AI systems in active use or regulated-industry exposure	Highest speed and consistency; requires budget approval
Fractional allocation of existing compliance/security role	Small-to-mid-size organizations piloting AI governance	Lower cost; risk of deprioritization under competing demands
External advisory support (e.g., TSEC)	Organizations needing to stand up the program quickly or pursue ISO/IEC 42001 certification	Fast, expert-led; requires ongoing internal ownership after handoff

Board Reporting Template

Boards and executive sponsors generally do not need phase-level operational detail — they need a concise, recurring answer to "are we exposed, and is it improving." Use the structure below for a quarterly AI governance update.

Section	Content
Current Maturity Level	Self-assessed level (Initial through Optimizing) and change since last report.
Inventory Coverage	% of known AI systems inventoried and risk-assessed.
Critical/High Risk Status	Number of Critical/High findings open, closed this period, and any accepted residual risk requiring board awareness.
Incidents	Any AI-related incidents or near-misses this period, and remediation status.
Regulatory Watch	Material regulatory changes (new state laws, EU AI Act milestones, sector guidance) relevant to the organization's AI footprint.
Upcoming Decisions	Any resourcing, certification (e.g., ISO/IEC 42001), or policy decisions requiring board input next quarter.

Keeping this report to a single page forces prioritization and makes it far more likely to actually be read and acted upon than a comprehensive but lengthy status document.

KPIs

Metrics turn "we have an AI governance program" into something that can be reported, defended to a board or auditor, and improved over time.

KPI	What It Indicates
% of known AI systems formally inventoried	Visibility — the foundation every other metric depends on.
% of inventoried systems risk-assessed	Whether Phase 2 is keeping pace with Phase 1.
% of Critical/High systems with documented mitigating controls	Whether the highest-risk exposure is actually being closed.

KPI	What It Indicates
Median time from AI use-case intake to approval decision	Whether governance is fast enough that teams use the process instead of routing around it.
Number of AI-related incidents and near-misses per quarter	Whether monitoring is catching problems before they become material.
% of employees completing AI acceptable-use training	Whether awareness controls are reaching the organization, not just existing on paper.

Common Pitfalls

1. Trying to run all five phases at full depth simultaneously rather than sequencing — Discover and initial Assess should complete before Govern is finalized.
2. Writing a comprehensive governance policy before understanding what is actually in the environment, resulting in a policy that does not match reality.
3. Declaring victory after Phase 4 and letting Monitor lapse, which is the single most common reason mature-looking programs quietly decay.
4. Under-resourcing the AI Governance Lead role by assuming it can be absorbed entirely into someone's existing workload without any dedicated time.

Next Steps

Organizations should expect this roadmap to span two to four quarters for a first pass through all five phases, with Monitor becoming a permanent, recurring function rather than a one-time phase. TSEC advises clients through each phase individually or as a full program — from the initial inventory workshop through ISO/IEC 42001 certification readiness — and can benchmark a specific organization's current maturity level as a starting point.

Glossary of Key Terms

Term	Definition
AI Governance Lead	The individual or committee accountable for day-to-day AI risk decisions and program operation.
Intake Process	The formal workflow by which a new AI use case is proposed, reviewed, and approved before deployment.
Maturity Model	A structured framework (e.g., Initial through Optimizing) describing how developed an organization's governance practices are.
Residual Risk	The risk remaining after mitigating controls have been applied, requiring formal owner acceptance.

Term	Definition
Risk Register	A documented, prioritized list of identified risks, their ratings, and assigned mitigation owners.

About TSEC & Next Steps

TSEC Risk & Cyber Advisory LLC helps SMBs, SaaS companies, FinTech, healthcare organizations, professional services firms, manufacturers, and government contractors build governance, risk management, and compliance programs that hold up under audit — and under real-world adversarial conditions. Our advisory work spans SOC 2, ISO 27001, NIST CSF, HIPAA, PCI DSS, NYDFS, and emerging AI governance requirements.

This resource is one part of a broader compliance library. Organizations that need help translating a checklist into an operating program — policies, control ownership, evidence collection, board reporting, and audit readiness — typically engage TSEC for structured advisory support rather than building it alone.

Work With TSEC

Book a Strategy Call — a working session to review your current AI governance posture against NIST AI RMF and ISO/IEC 42001, and identify the highest-priority gaps.

Email: Info@tsecgrc.com

Web: www.tsecgrc.com

Visit www.tsecgrc.com/resources for the full compliance resource library

© 2026 TSEC Risk & Cyber Advisory LLC. This resource is provided for general informational and educational purposes and does not constitute legal advice. Organizations should consult qualified legal counsel to assess specific regulatory obligations.